

SECURE DEVELOPMENT PRACTICES

Revision: 1.0

Issue Status: A

Prepared by	Designation
Prasath P	Associate Director of Technology
Approved by	Designation
Arunkumar G	Senior Director Technology

This document is the property of and proprietary to I2I. Contents of this document should not be disclosed to any unauthorized person. This document may not, in whole or in part, be reduced, reproduced, stored in a retrieval system, translated, or transmitted in any form or by any means, electronic or mechanical.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	1 of 22

Revision History

#	Version	Release Date	Description of the Change	Created/ Modified by	Approved by
1	1.0	05-Feb-2024	Initial	Prasath P	Arunkumar G

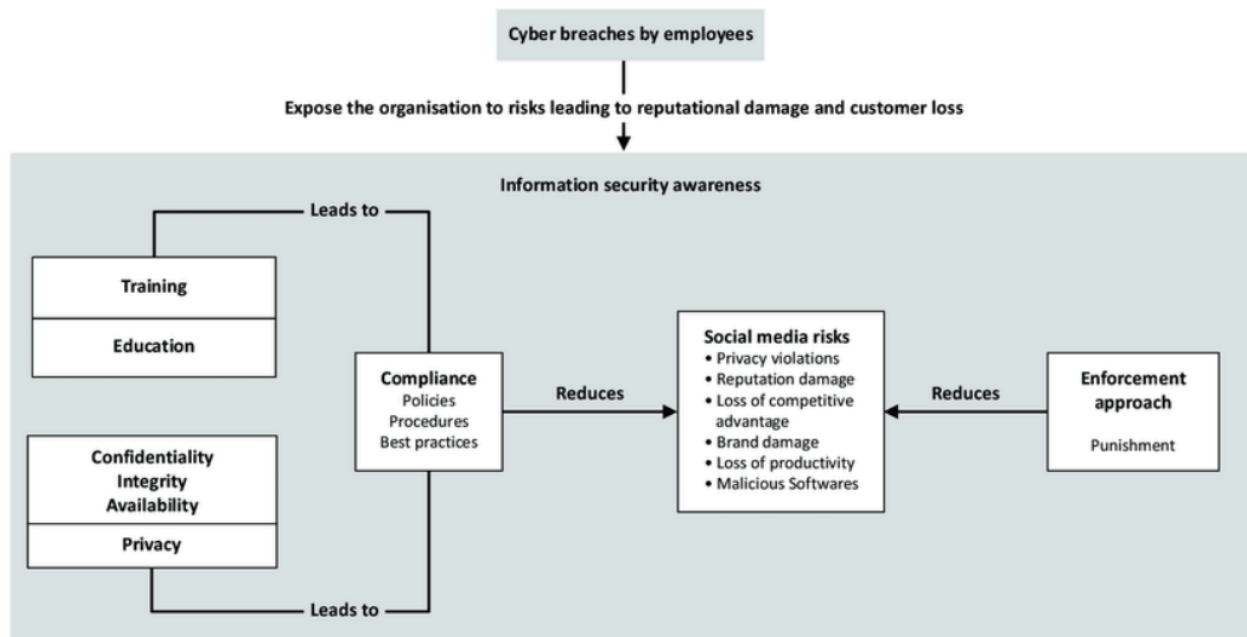
Review History

#	Version	Review Date	Description	Created/ Modified by	Reviewed by
1	1.0	05-Feb-2024	Initial	Prasath P	Arunkumar G

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	2 of 22

General Security Awareness

General security awareness is essential for protecting yourself and your organization from various threats, including cyberattacks, data breaches, and physical security risks. Here are some key concepts to keep in mind:



Recognizing Threats

- ❖ **Phishing:** Be cautious of unsolicited emails or messages that request personal information. Look for suspicious links or attachments.
- ❖ **Social Engineering:** Understand tactics used by attackers to manipulate individuals into divulging confidential information.
- ❖ **Malware:** Be aware of software designed to harm or exploit devices, including viruses, ransomware, and spyware.

Safe Practices

Implementing safe practices is essential for minimizing security risks. Here are key practices to consider:

- ❖ **Password Management**

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	3 of 22

- **Use Strong Passwords:** Create complex passwords that are at least 12 characters long, incorporating a mix of letters, numbers, and symbols.
- **Unique Passwords:** Avoid reusing passwords across different accounts. Each account should have its own distinct password.
- **Password Managers:** Utilize password managers to generate and store strong passwords securely.
- ❖ **Two-Factor Authentication (2FA)**
 - **Enable 2FA:** Whenever available, activate two-factor authentication for an extra layer of security. This typically involves receiving a code via SMS or using an authentication app.
 - **Backup Codes:** Store backup codes securely in case you lose access to your 2FA method.
- ❖ **Regular Software Updates**
 - **Automatic Updates:** Enable automatic updates for your operating system and applications to ensure you have the latest security patches.
 - **Antivirus and Anti-Malware:** Keep antivirus software up to date and run regular scans to detect and remove threats.
- ❖ **Data Protection**
 - **Encryption:** Use encryption tools for sensitive files and communications to protect data during storage and transmission.
 - **Backup Regularly:** Implement a regular backup schedule for critical data, utilizing both local and cloud solutions.
- ❖ **Secure Your Devices**
 - **Lock Screens:** Use a password, PIN, or biometric authentication (fingerprint/face recognition) to lock your devices.
 - **Remote Wipe Capability:** Enable remote wiping features on your devices to erase data if they are lost or stolen.
- ❖ **Public Wi-Fi Precautions**
 - **Avoid Sensitive Transactions:** Refrain from accessing sensitive accounts or conducting financial transactions over public Wi-Fi.
 - **Use a VPN:** Consider using a Virtual Private Network (VPN) to encrypt your internet connection when using public networks.
- ❖ **Physical Security Measures**
 - **Secure Your Workspace:** Lock your computer when stepping away and keep sensitive documents secured.
 - **Access Control:** Limit access to physical spaces with sensitive information or equipment.
- ❖ **Incident Response**

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	4 of 22

- **Know the Protocol:** Familiarize yourself with your organization's incident response plan for reporting security incidents.
- **Stay Calm:** If you suspect a breach, act quickly but thoughtfully to minimize potential damage.
- ❖ **Continuous Learning**
 - **Stay Informed:** Regularly participate in security awareness training and stay updated on the latest security threats and trends.
 - **Share Knowledge:** Encourage discussions about security practices with colleagues to foster a culture of security.

Culture of Security

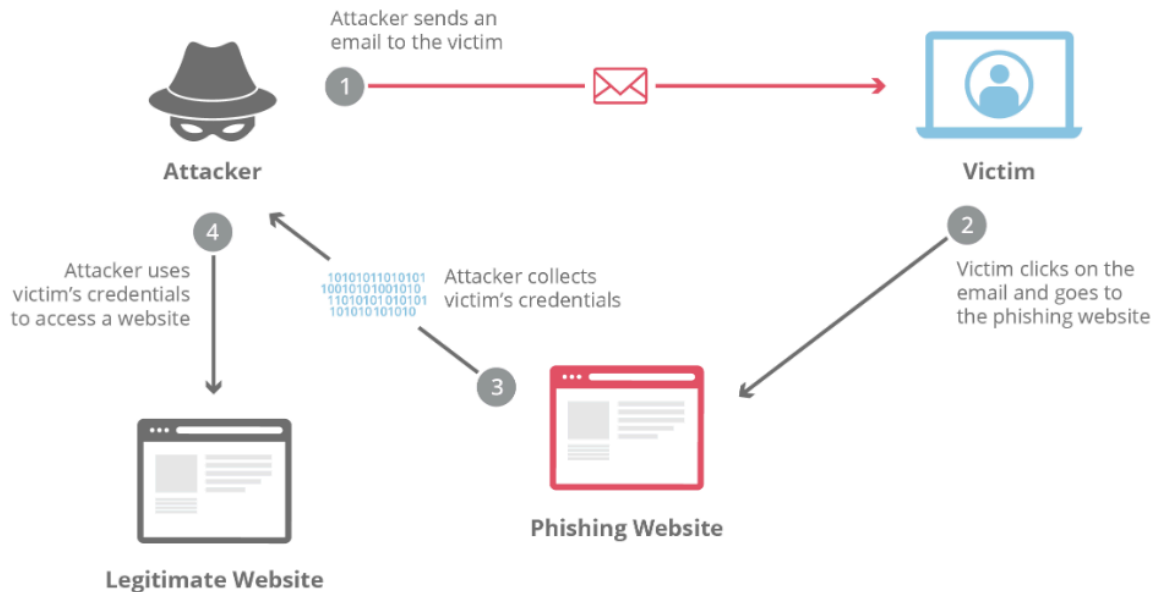
- ❖ **Encourage Awareness:** Promote a culture where security is everyone's responsibility. Share knowledge and experiences with colleagues.
- ❖ **Stay Vigilant:** Regularly assess your security practices and remain vigilant about potential risks.

Email and Phishing

Phishing

Phishing is a deceptive practice where attackers impersonate legitimate entities to trick individuals into providing sensitive information (like passwords, credit card details, or personal information).

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	5 of 22



Types of Phishing:

- ❖ **Spear Phishing:** Targeted attacks aimed at specific individuals or organizations.
- ❖ **Whaling:** A form of spear phishing that targets high-level executives.
- ❖ **Vishing:** Phishing via phone calls.
- ❖ **Smishing:** Phishing via SMS texts.

Recognizing Phishing Emails

- ❖ **Suspicious Sender:** Check the sender's email address carefully; look for slight misspellings or unusual domains.
- ❖ **Generic Greetings:** Be cautious of emails that use generic salutations like "Dear Customer" instead of your name.
- ❖ **Urgent Language:** Phishing emails often create a sense of urgency, prompting immediate action (e.g., "Your account will be suspended").
- ❖ **Unexpected Attachments or Links:** Avoid clicking on links or downloading attachments from unknown sources.
- ❖ **Poor Grammar and Spelling:** Many phishing emails contain grammatical errors or awkward phrasing.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	6 of 22

Safe Email Practices

- ❖ **Verify Sources:** Always verify the legitimacy of requests by contacting the organization directly through official channels (not through contact information provided in the suspicious email).
- ❖ **Hover Before Clicking:** Hover over links to see the actual URL before clicking. Ensure it matches the expected domain.
- ❖ **Avoid Public Wi-Fi:** Don't access sensitive accounts over unsecured networks, which can be monitored by attackers.

Reporting Suspicious Emails

- ❖ **Internal Protocols:** Familiarize yourself with your organization's procedure for reporting suspicious emails or phishing attempts.
- ❖ **Use Security Tools:** Utilize built-in email security features, such as spam filters and reporting functions.

Training and Awareness

- ❖ **Regular Training Sessions:** Conduct training on recognizing phishing attempts and the importance of email security.
- ❖ **Simulated Phishing Attacks:** Implement simulated phishing exercises to help employees practice identifying phishing emails.

Incident Response

- ❖ **Know What to Do:** If you suspect you've received a phishing email, do not click any links or provide information. Report it immediately.
- ❖ **Monitor Accounts:** Keep an eye on your accounts for any unauthorized transactions or changes, especially after encountering suspicious emails.

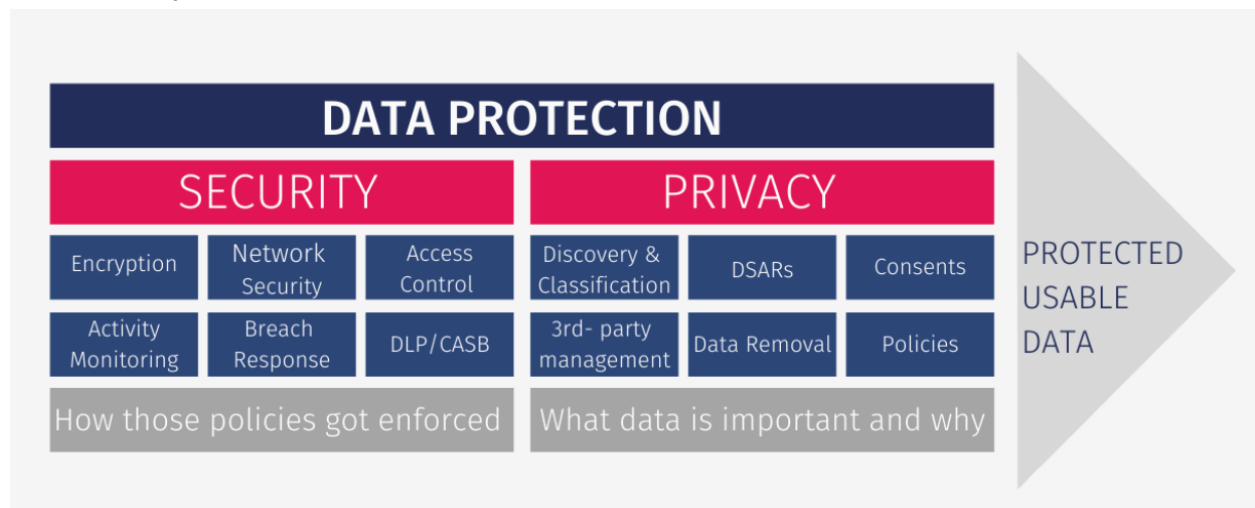
Use of Security Tools

- ❖ **Email Filtering:** Utilize advanced email filtering solutions that identify and block phishing emails.
- ❖ **Multi-Factor Authentication (MFA):** Enable MFA on your accounts to add an extra layer of security, making it harder for attackers to gain access even if they obtain your password.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	7 of 22

Data Protection and Privacy

Protecting sensitive data is critical for ensuring privacy and compliance with regulations. Here's a comprehensive overview of best practices for handling various types of sensitive data, including Personally Identifiable Information (PII), Health Insurance Portability and Accountability Act (HIPAA) data, financial information, and health records.



Understanding Sensitive Data

- ❖ **Personally Identifiable Information (PII):** Any data that can be used to identify an individual (e.g., names, addresses, Social Security numbers).
- ❖ **HIPAA Data:** Protected health information (PHI) related to an individual's health status, healthcare provision, or payment for healthcare.
- ❖ **Financial Information:** Data related to an individual's financial status, including bank account details, credit card numbers, and income information.
- ❖ **Health Records:** Comprehensive medical records that include treatment history, diagnoses, and test results.

Data Classification

- ❖ **Identify and Classify:** Determine what constitutes sensitive data within your organization and classify it based on sensitivity levels.
- ❖ **Access Control:** Limit access to sensitive data to authorized personnel only, based on their roles and responsibilities.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	8 of 22

Data Encryption

- ❖ **Encryption at Rest and in Transit:** Use encryption to protect sensitive data both when stored (at rest) and when being transmitted over networks (in transit).
- ❖ **Secure Protocols:** Utilize secure communication protocols such as HTTPS and VPNs for data transmission.

Data Minimization

- ❖ **Collect Only Necessary Data:** Only collect data that is essential for your operations and avoid gathering unnecessary information.
- ❖ **Limit Retention:** Retain sensitive data only as long as necessary for business purposes or legal compliance. Securely delete data when it is no longer needed.

Secure Data Storage

- ❖ **Use Secure Storage Solutions:** Store sensitive data in secure environments, such as encrypted databases or secure cloud services.
- ❖ **Regular Backups:** Implement regular backups of sensitive data to protect against loss or corruption.

Access Controls and Authentication

- ❖ **Role-Based Access Control (RBAC):** Implement RBAC to ensure individuals only have access to the data necessary for their job functions.
- ❖ **Multi-Factor Authentication (MFA):** Use MFA to enhance security for accessing sensitive data and systems.

Compliance with Regulations

- ❖ **Know the Regulations:** Familiarize yourself with applicable laws and regulations governing data protection, such as GDPR, HIPAA, and PCI-DSS.
- ❖ **Conduct Regular Audits:** Regularly audit your data protection practices and compliance status to ensure adherence to relevant regulations.

Employee Training and Awareness

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	9 of 22

- ❖ Regular Training: Provide ongoing training to employees on data protection best practices and the importance of handling sensitive information securely.
- ❖ Phishing Awareness: Educate staff about the risks of phishing and social engineering attacks that target sensitive data.

Incident Response Plan

- ❖ Develop a Response Plan: Create a data breach response plan outlining steps to take in the event of a data breach, including notification procedures.
- ❖ Regular Testing: Regularly test and update your incident response plan to ensure effectiveness.

Data Sharing and Third-Party Management

- ❖ Secure Sharing Protocols: Use secure methods for sharing sensitive data, such as encrypted emails or secure file transfer services.
- ❖ Third-Party Risk Management: Assess and monitor the security practices of third-party vendors that handle sensitive data on your behalf.

Incident Reporting and Monitoring

Incident reporting and monitoring are critical components of incident management, aimed at identifying, documenting, and analyzing incidents that disrupt normal operations. These processes help organizations respond effectively to incidents, minimize their impact, and prevent recurrence.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	10 of 22



What is Incident Reporting?

Incident Reporting is the systematic process of documenting any event that disrupts or has the potential to disrupt normal operations. This can include a wide range of incidents, from IT service failures to workplace accidents. The primary goal of incident reporting is to ensure that all relevant information is captured immediately after an incident occurs to facilitate timely action and resolution.

Key Steps in Incident Reporting

1. Identification: Recognizing that an incident has occurred is the first step. This can be initiated by any employee or automated monitoring systems.
2. Documentation: Collecting detailed information about the incident, including:
 - Type of incident
 - Individuals involved
 - Location and time of occurrence
 - Severity and potential causes
 - Supporting evidence (e.g., photos, logs)

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	11 of 22

- Submission: The collected information is submitted through an incident report form or management system for further analysis and action.

Importance of Incident Reporting

- **Timely Response:** Quick reporting allows organizations to respond rapidly to mitigate the impact of the incident.
- **Data Collection:** Structured reports help in gathering valuable data that can reveal patterns or recurring issues.
- **Root Cause Analysis:** Detailed documentation aids in identifying underlying causes, which can inform preventive measures.

What is Incident Monitoring?

Incident Monitoring involves the ongoing observation and evaluation of reported incidents to track their status and effectiveness of responses. This process ensures that incidents are resolved efficiently and helps in identifying trends over time.

Key Features of Incident Monitoring

- Real-Time Tracking:** Monitoring systems provide dashboards that display the current status of incidents, allowing stakeholders to see open, in-progress, and resolved incidents at a glance.
- Alerts and Notifications:** Automated notifications can be sent to relevant personnel when an incident is reported or when there are updates on its status.
- Performance Metrics:** Monitoring tools often include key performance indicators (KPIs) such as average resolution time, number of incidents by type, and compliance with service level agreements (SLAs).

Benefits of Incident Monitoring

- **Improved Accountability:** Tracking who is responsible for resolving each incident enhances accountability within teams.
- **Enhanced Communication:** Effective monitoring facilitates better communication among team members regarding the status of incidents.
- **Continuous Improvement:** By analyzing trends in incident data, organizations can implement changes to reduce future incidents.

Tools for Incident Reporting and Monitoring

Organizations often utilize specialized software solutions for incident reporting and monitoring. These tools typically include features such as:

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	12 of 22

- Incident Tracking: A central hub for recording details about incidents and tracking their progress.
- Data Visualization: Graphical representations (charts, graphs) to help identify patterns and trends in incident data.
- Mobile Access: Allowing users to report and monitor incidents from mobile devices for greater flexibility.
- Comprehensive Reporting: Generating detailed reports that summarize incidents over specified periods for review by management.

Conclusion

Effective incident reporting and monitoring are essential for maintaining operational integrity within organizations. By implementing structured processes and utilizing appropriate tools, businesses can ensure rapid response to incidents, minimize disruptions, and foster a culture of continuous improvement through learning from past events. This proactive approach not only enhances safety but also contributes to overall organizational resilience.

Physical Security

What is Physical Security?

Physical security is the protection of personnel, facilities, equipment, and resources from physical actions and events that could cause damage or loss. It involves implementing measures to prevent unauthorized access, detect intrusions, and respond to security incidents. The main goal of physical security is to safeguard an organization's tangible assets and ensure the safety of its employees and visitors.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	13 of 22



Key Components of Physical Security

1. Access Control: Limiting and controlling access to facilities, equipment, and resources to authorized personnel only. This includes measures such as ID badges, keypads, security guards, and more sophisticated systems like biometric scanners and NFC ID cards.
2. Surveillance: Monitoring activities in different locations using technology (e.g., CCTV), personnel (e.g., security guards), and other resources. Surveillance helps prevent incidents and aids in post-incident recovery.
3. Testing and Training: Regular evaluation of security systems to ensure their effectiveness and comprehensive training for personnel to handle potential physical security scenarios.

Physical Security Measures

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	14 of 22

1. Deterrence Methods: Convincing potential attackers that a successful attack is unlikely due to strong defenses. Examples include warning signs, security lighting, fences, and vehicle barriers.
2. Alarm Systems and Sensors: Alerting security personnel of unauthorized access attempts or held/forced doors. Integration with camera systems is common.
3. Identification Systems and Access Policies: Using policies, processes, and procedures to manage ingress into restricted areas, often supplemented by mechanical and electronic access control.
4. Surveillance Systems: Monitoring activities in different locations using CCTV, security guards, and other resources. Surveillance helps prevent incidents and aids in post-incident recovery.
5. Testing and Training: Regular evaluation of security systems to ensure their effectiveness and comprehensive training for personnel to handle potential physical security scenarios.

Importance of Physical Security

1. Protecting People, Property, and Assets: Physical security measures safeguard employees, facilities, equipment, and other tangible assets from theft, damage, or destruction.
2. Preventing Unauthorized Access: Access control systems limit exposure of certain assets to authorized personnel only, reducing the risk of data breaches and other security incidents.
3. Mitigating Risks: By implementing robust physical security measures, organizations can effectively manage and mitigate various threats, including natural disasters, fires, and terrorist acts.
4. Ensuring Business Continuity: Effective physical security helps prevent or minimize disruptions to an organization's operations, ensuring business continuity and protecting its reputation.
5. Complying with Regulations: Many industries have specific regulations and standards related to physical security that organizations must adhere to, such as the Payment Card Industry Data Security Standard (PCI DSS) for the payment card industry.

Best Practices for Physical Security

1. Adopt a Risk-Based Approach: Evaluate scenarios based on the organization's risk profile and invest in physical security measures accordingly.
2. Implement Layered Security: Use multiple layers of interdependent systems, such as fences, walls, alarms, and surveillance cameras, to create a comprehensive defense.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	15 of 22

3. Regularly Review and Update Security Measures: Continuously assess the effectiveness of physical security measures and make necessary adjustments to address evolving threats and changing requirements.
4. Foster a Culture of Security Awareness: Educate employees about physical security protocols and encourage them to report suspicious activities or potential vulnerabilities.
5. Collaborate with Law Enforcement and Security Professionals: Work closely with local law enforcement agencies and security experts to stay informed about the latest threats and best practices in physical security.

By understanding the principles of physical security and implementing a combination of access control, surveillance, and testing measures, organizations can effectively protect their assets and ensure the safety of their personnel

Device Security



What is Device Security?

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	16 of 22

Device security refers to the process of safeguarding mobile phones, laptops, PCs, tablets, and Internet of Things (IoT) devices from cyberthreats and unauthorized access. It involves implementing measures to protect sensitive data, prevent data breaches, and ensure the overall security of internet-connected devices.

Key Components of Device Security

1. **Strong Authentication:** Implementing robust authentication methods such as PIN codes, passwords, biometrics (e.g., fingerprint or facial recognition), and multifactor authentication (MFA) to verify user identity and prevent unauthorized access.
2. **Mobile Device Management (MDM):** Using MDM tools to enforce security policies, control access to corporate data, and remotely manage and secure mobile devices.
3. **Network Access Control:** Restricting network access to authorized devices and monitoring network activity for suspicious behavior to detect and prevent potential threats.
4. **Data Encryption:** Enabling device encryption to protect sensitive data stored on mobile devices in case of loss or theft.
5. **Application Security:** Ensuring that apps downloaded from trusted sources are secure and do not contain malware or other malicious code that could compromise device security.

Best Practices for Device Security

1. **Keep devices updated:** Regularly update operating systems, apps, and security software to address known vulnerabilities and protect against the latest threats.
2. **Use strong passwords and enable MFA:** Create complex passwords, change them frequently, and enable multifactor authentication whenever possible to add an extra layer of security.
3. **Be cautious with public Wi-Fi:** Avoid using unsecured public Wi-Fi networks, as they can expose devices to potential attacks. Use a VPN or avoid accessing sensitive information when connected to public hotspots.
4. **Avoid rooting or jailbreaking devices:** Rooting or jailbreaking devices can bypass built-in security measures and make them more vulnerable to malware and other threats.
5. **Use device tracking and remote wipe capabilities:** Enable device tracking and remote wipe functionality to locate lost or stolen devices and erase sensitive data if necessary.
6. **Implement a BYOD (Bring Your Own Device) policy:** Establish clear guidelines for employees using personal devices for work purposes, including security requirements and acceptable use policies.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	17 of 22

- Educate employees on device security best practices: Train employees on how to identify and avoid potential threats, such as phishing attempts and social engineering attacks targeting mobile devices.

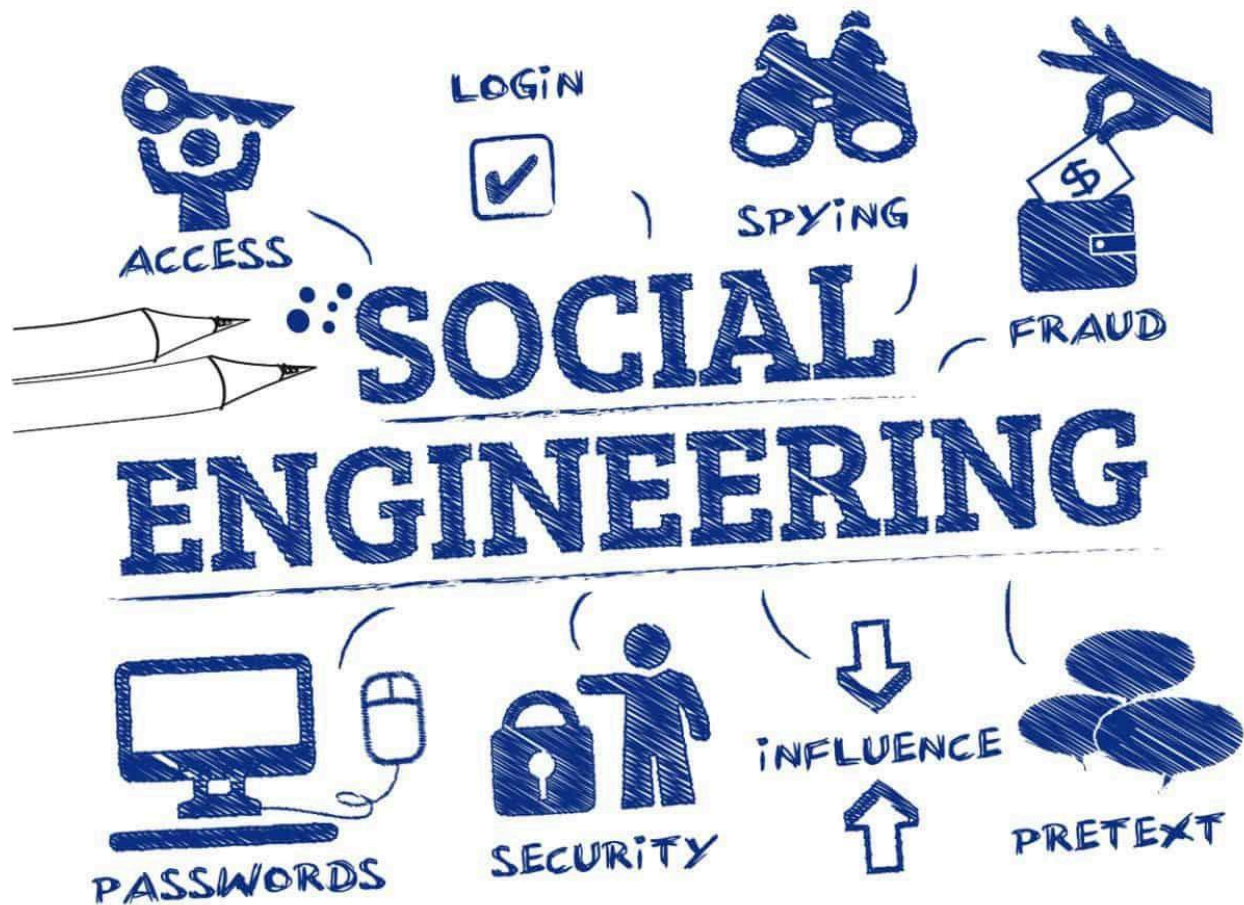
Benefits of Effective Device Security

- Data Protection:** Safeguarding sensitive data stored on mobile devices and preventing unauthorized access or data breaches.
- Compliance:** Ensuring that organizations adhere to industry regulations and standards related to data security and privacy.
- Reduced Risk:** Minimizing the risk of device-related security incidents, such as malware infections, data loss, and reputational damage.
- Improved Productivity:** Enabling secure access to corporate resources and applications from mobile devices, enhancing employee productivity and collaboration.
- Business Continuity:** Ensuring that critical business operations can continue uninterrupted in the event of a security incident or device loss/theft.

By implementing a comprehensive device security strategy that combines strong authentication, MDM, network access control, and employee education, organizations can effectively protect their devices and the sensitive data they contain from various threats.

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	18 of 22

Social Engineering Awareness



1. Purpose:

- a. To make employees aware that (a) fraudulent social engineering attacks occur, and (b) there are procedures that employees can use to detect attacks.
 - i. Employees are made aware of techniques used for such attacks, and they are given standard procedures to respond to attacks.
 - ii. Employees know who to contact in these circumstances.
 - iii. Employees recognize they are an important part of Company's security. The integrity of an employee is the best line of defense for protecting sensitive information regarding Company's resources.
- b. To create specific procedures for employees to follow to help them make the best choice when:

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	19 of 22

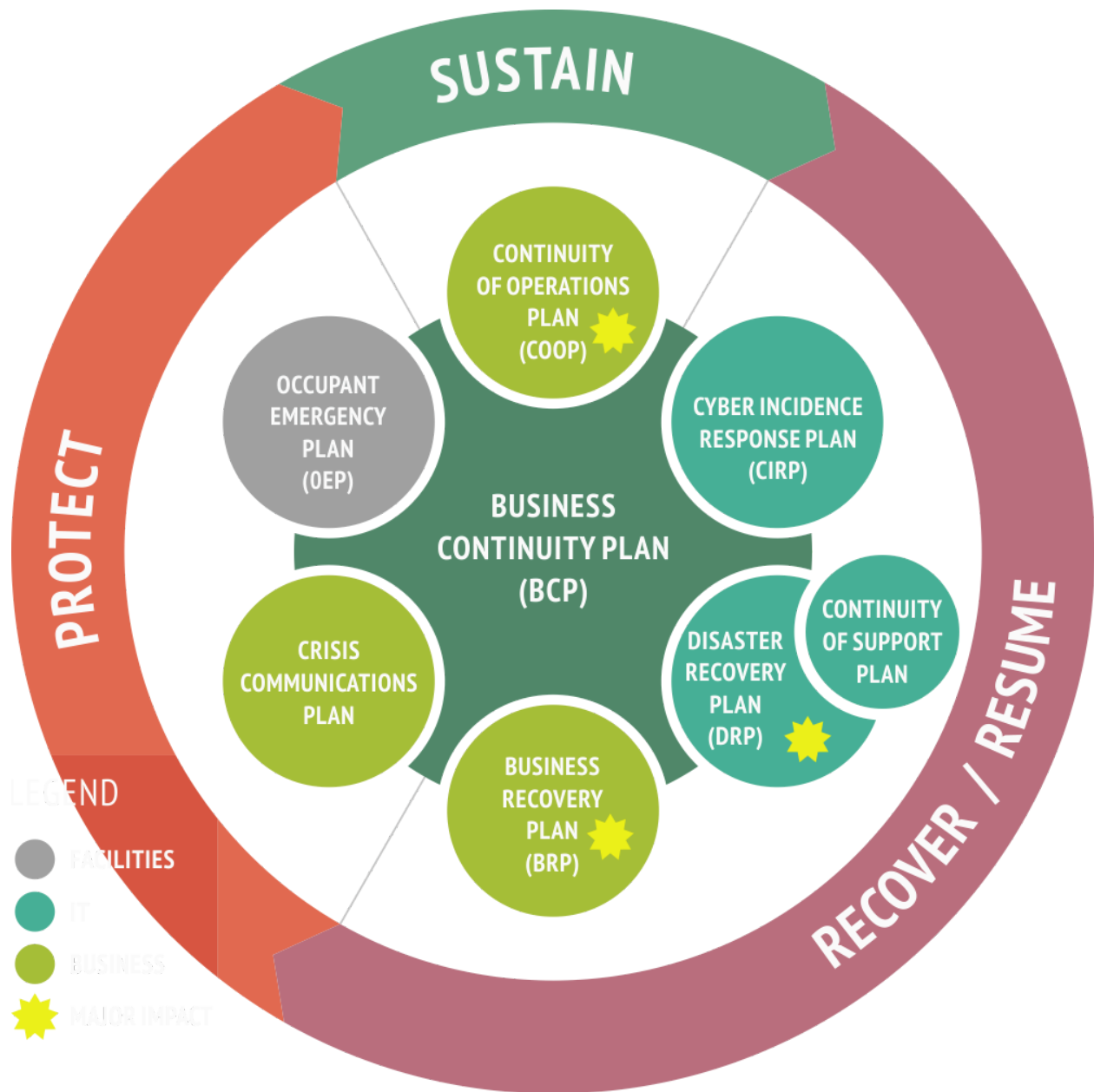
- i. Someone is contacting the employee - via phone, in person, email, fax or online - and elusively trying to collect Company's sensitive information.
- ii. The employee is being "socially pressured" or "socially encouraged or tricked" into sharing sensitive data.

2. Awareness:

- Sensitive information of Company will not be shared with an unauthorized individual if he/she uses words and/ or techniques such as the following:
 - An "urgent matter"
 - A "forgotten password"
 - A "computer virus emergency"
 - Any form of intimidation from "higher level management"
 - Any "name dropping" by the individual which gives the appearance that it is coming from legitimate and authorized personnel.
 - The requester requires release of information that will reveal passwords, model, serial number, or brand or quantity of Company resources.
 - The techniques are used by an unknown (not promptly verifiable) individual via phone, email, online, fax, or in person.
 - The techniques are used by a person that declares to be "affiliated" with Company such as a sub-contractor.
 - The techniques are used by an individual that says he/she is a reporter for a well-known press editor or TV or radio company.
 - The requester is using ego and vanity seducing methods, for example, rewarding the front desk employee with compliments about his/her intelligence, capabilities, or making inappropriate greetings (coming from a stranger).
- All persons MUST attend the security awareness training within 30 days from the date of employment and every 6 months thereafter.
- If one or more Incident report circumstances is detected by a person, then the identity of the requester MUST be verified before continuing the conversation or replying to email, fax, or online.
- If the identity of the requester CANNOT be promptly verified, the person MUST immediately contact his/her supervisor or direct manager.
- If the supervisor or manager is not available, that person MUST contact the security personnel.
- If the security personnel is not available, the person MUST immediately drop the conversation, email, online chat with the requester, and report the episode to his/her supervisor before the end of the business day.

Disaster Management and Business Continuity Plan

 Let's Innovate	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	20 of 22



1. Purpose:

- This policy defines the requirement for a baseline disaster recovery plan to be developed and implemented by the Company that will describe the process to

	SECURE DEVELOPMENT PRACTICES	Document Number	I2I/SOC2/ITPP
		Date	05/02/2024
		Revision No	1.0
		Page	21 of 22

recover IT Systems, Applications and Data from any type of disaster that causes a major outage.

2. Scope

- This policy is directed to the IT Management Staff who is accountable to ensure the plan is developed, tested and kept up-to-date. This policy is solely to state the requirement to have a disaster recovery plan, it does not provide a requirement around what goes into the plan or sub-plans.

3. Contingency Plans:

- Computer Emergency Response Plan: Who is to be contacted, when, and how? What immediate actions must be taken in the event of certain occurrences?
- Succession Plan: Describe the flow of responsibility when normal staff is unavailable to perform their duties.
- Data Study: Detail the data stored on the systems, its criticality, and its confidentiality.
- Criticality of Service List: List all the services provided and their order of importance.
- It also explains the order of recovery in both short-term and long-term timeframes.
- Data Backup and Restoration Plan: Detail which data is backed up, the media to which it is saved, where that media is stored, and how often the backup is done. It should also describe how that data could be recovered.
- Equipment Replacement Plan: Describe what equipment is required to begin to provide services, list the order in which it is necessary, and note where to purchase the equipment.
- Mass Media Management: Who is in charge of giving information to the mass media?
- Also provide some guidelines on what data is appropriate to be provided.

After creating the plans, it is important to practice them to the extent possible. Management should set aside time to test implementation of the disaster recovery plan. Table top exercises should be conducted annually. During these tests, issues that may cause the plan to fail can be discovered and corrected in an environment that has few consequences.

The plan, at a minimum, should be reviewed and updated on an annual basis.